



JÖNKÖPING UNIVERSITY
School of Engineering

EsacOmed – A Risk Management Assignment

Group name: 5

Members: Mohamed Ibrahim Mohamed Gani,
Tesfaldet Tesfamariam Weldemicheal,
Vinh Khiem Bui

Cybersecurity Overview – TCSR24

Jönköping - 10 / 2025

Table of Contents

I	Introduction	3
2	Risk management process	4
2.1,	RISK IDENTIFICATION	4
2.1.1.	Customer Payment Card Data (PCI DSS Data).....	5
2.1.2	Funds Transfer Execution System.....	5
2.1.3	TLS/SSL Private Key	6
2.1.4	Source Code	6
2.1.5	User Authentication Database	6
2.2	RISK ANALYSIS.....	6
2.2.1.	Customer Payment Card Database.....	6
2.2.2	Funds Transfer Execution System	7
2.2.3	TLS/SSL Private Key	7
2.2.4	Employee User Accounts (Active Directory)	7
2.2.5	Source Code	8
2.3	RISK EVALUATION.....	8
2.3.1	Risk Acceptance Criteria:	8
2.3.2	Prioritized Risk List:	8
2.4	RISK TREATMENT	9
2.5	RISK MONITORING AND REVIEWING.....	9
2.5.1	Monitoring	9
2.5.2	Review Process	9
2.6	RISK REGISTER MAINTENANCE	10
3	Conclusion	11
4	Reference.....	13

1 Introduction

With this assignment, EsacOmed – A Risk Management Exercise, we will be required to build and demonstrate an Information Security Risk Management (ISRM) process for a possible SME organization (Lundgren, 2025). EsacOmed is a small company that provides information technology (IT) services. It employs twenty-four people and operates according to outmoded IT standards (Lundgren, 2025). Lundgren (2025) states that they are competing for a federal contract that demands a rigorous ISRM approach. The organization has a number of shortcomings, including a lack of current security rules, insufficient technical controls, and poor operational habits. These poor operational habits include the use of weak passwords, software that is out of date, and unencrypted WiFi (Lundgren, 2025).

Group 5 operates as independent security consultants who have been employed to assist them in fulfilling the conditions of their contract. EsacOmed offers a payment gateway solution to its customers. They provide internet shops with the ability to credit card payments, process them, and transfer monies. Through the provision of secure and efficient online business capabilities, the EsacOmed service "empowers every organization on the planet to achieve more," according to Lundgren (2025).

These dangers cannot be disregarded by EsacOmed. In addition, the company is attempting to secure a government procurement contract, which entails providing clear evidence that information security risks are being addressed in a methodical manner (Guan, 2024, May). This is not only about adhering to the rules, but it is also about building trust. If customers do not feel confidence that their payment information is secure, they will stop using the service. It is essential that consumers feel secure in the knowledge that their payment data is protected. As a result, this paper is intended to illustrate how a structured risk management approach that is founded on ISO/IEC 27005 can be implemented in conjunction with EsacOmed's e-Payment systems (Seaman, 2020).

2 Risk management process

As explained in the introduction EsacOmed offer a payment solution to the customer and the company has selected a risk management system that follows the ISO/IEC 27005. This standard support to implement the risk assessment process and this process includes, risk identification, risk analysis, evaluation, risk treatment risk monitor and register. Following this process the company's payment information can be secure (Mahfud, 2024, August) Risk identification is the first step. It means finding important assets that are important to the business's operations or reputation and figuring out how safe they are. This sets the stage for the next step, which is a risk analysis that looks closely at each important asset. This means figuring out what threats and weaknesses are, what could happen, and how likely these risks are to happen.

The risk evaluation phase ranks the risks by comparing them to pre-set risk acceptance criteria. This helps find the risks that need to be dealt with right away (Endro Joko Wibowo, 2022). The risk treatment phase begins after the risks have been looked at. This is when people make plans and carry them out to deal with the risks. Some of these strategies could be putting security measures in place, weighing the costs and benefits of taking risks, avoiding risks by stopping risky activities, or moving risks to safer places, like cloud hosting.

Keeping an eye on risks all the time makes sure that the controls that have been put in place are working and lets the organization know when the threat landscape changes. This is done in addition to regular reviews to make sure that the risk management process is still working. Risk registration and maintenance are very important throughout the entire lifecycle because they keep track of all risk-related information, decisions, and treatment actions in a central risk register.

2.1, Risk Identification

Critical Assets identification and Valuation for an E-payment: for an E-Payment company, the following five assets are undoubtedly critical. Their compromise would directly lead to financial loss, regulatory fines, and loss of customer trust.

- Customer Payment Card Data (PCI DSS Data)
- Funds Transfer Execution System
- TLS/SSL Private Key
- User Authentication Database
- Source Code

Tabell 1 Asset, Threats, and Vulnerabilities

Asset	Threats	Vulnerabilities
Customer Payment Card Data (PCI DSS Data)	SQL injection attacks, Data theft	Outdated software (CentOS 5.10, Apache 2.2.34), Weak network segmentation
Funds Transfer Execution System	Unauthorized fund transfers, System manipulation	Shared SSH keys, Weak VM passwords, No network isolation
TLS/SSL Private Key	Key theft, Man-in-the-middle attacks	Stored on USB stick, Copied to developer computers
User Authentication Database	Credential theft, Unauthorized access	Weak default passwords ("surname123"), No password policy
Source code	Intellectual property theft, Code manipulation	Outdated git server (v1.9.1), Shared user accounts

2.1.1. Customer Payment Card Data (PCI DSS Data)

The most valuable possession Credit card details (number, expiration date, cardholder name), billing information, transaction history, and card verification value (CVV) codes are all part of this. Lundgren (2025) states that it is saved in the MySQL database, which is located on the Web Server. This information is the most sensitive. Financial fraud is a direct consequence of its misappropriation. Any breach of confidentiality would not only result in direct financial fraud but also prompt legal action under Payment Card Industry Data Security Standards (PCI DSS) and GDPR, it is essential that the privacy of this asset is prevented. EsacOmed required to follow the Payment Card Industry Data Security Standards (PCI DSS), which include stringent security requirements.

2.1.2 Funds Transfer Execution System

The Production Server is responsible for initiating transfers of payments from the accounts of customers to those of merchants. It verifies, authorizes, and finalizes transactions between suppliers and their custom. Its most important feature is its availability, since even brief periods of unavailability would make transactions impossible, which would result in an immediate loss of revenue as well as damage to its reputation. The ability to directly manage finances It is possible that attackers will be able to reroute money into their own accounts if integrity is compromised (Seaman, 2020).

2.1.3 TLS/SSL Private Key

The private key that is utilized by the Web Server to encrypt all of the traffic on the internet, including payment pages and login pages. Furthermore, these are used to provide secure communication between users and the electronic payment platform. If they were not there, sensitive data would be transmitted in plaintext, which would make it simple for attackers to intercept it. In addition, certificates act as a basis of trust, and if they are compromised or misused, customers may lose faith in the platform. If an attacker were to obtain it, they would be able to decrypt any intercepted conversation, which would allow them to steal login passwords and payment information (Kumar, 2024). One of the most significant weaknesses is that both the developers' PCs and a USB stick are used to store data.

2.1.4 Source Code

The proprietary code for the payment processing application, stored on the Source Control Server (git). The code contains business logic, API keys, and potentially hardcoded secrets. Its theft could reveal vulnerabilities to attackers or allow a competitor to copy the service (Xu, 2023). The use of an older git server, such as version 1.9.1, enables an attacker to execute arbitrary code by generating malicious git trees, thus this vulnerability is a security risk. Insufficient safeguards against new authentication technologies and security patches (Xu, 2023).

2.1.5 User Authentication Database

EsacOmed employee identities and passwords are stored in the database (a component of Active Directory on the Mail/AD Server). Shared accounts and weak passwords (such as "surname123") make it simple for hackers to gain access to the internal network, which serves as a gateway to the payment systems. It has recovery options, multi-factor authentication (2FA), and passwords. Unauthorized access to even one account could result in data theft or transaction manipulation, therefore these weaknesses could be fatal (Lundgren, 2025).

2.2 Risk Analysis

This part covers detailed analysis of each critical asset including specific threats, vulnerabilities, impact justification, and likelihood assessment.

2.2.1. Customer Payment Card Database

The data breach that occurs as a result of a SQL injection attack is the threat that comes with the Customer Payment Card Database. Outdated web server software (CentOS 5.10, Apache 2.2.34, and MySQL 5.5.58) that is known to have security flaws is the source of the vulnerability. The Justification of the Impact (5/5): This would be

catastrophic since it would lead to large regulatory fines (non-compliance with the PCI Data Security Standard), litigation from financial institutions, a complete loss of trust from customers, and the possibility of a business going bankrupt. Justification Relating to Likelihood (4/5): Most likely - Automated assaults are very likely to occur on a server that is accessible to the public and runs old software that contains known vulnerabilities.

2.2.2 Funds Transfer Execution System

Unauthorized transfer of funds by the attacking party is the threat. Vulnerability is that SSH keys that are shared and passwords that are not strong on virtual machines used for production servers. The validation of the impact 5/5 which leads to direct financial loss. The risk in this scenario can lead to unchangeable transaction and fake transfer. As a result of it the output leads to the company's failure which can refer to a catastrophic. Because of this immediate action is required to mitigate the problem. When it comes to the validation or justification for the likelihood 3/5 and this means that the weak internal control generates opportunities however to exploit them the attacker must first breach the perimeter defenses.

2.2.3 TLS/SSL Private Key

Hackers pose a threat when they steal private keys, which allows them to decrypt communications. constitute the Exposure Keep key on developer PCs and USB sticks for "debugging purposes" in an unsecured manner. Analysis of the Impacts (4/5): Exposed client login and payment details result in decryption of all encrypted online traffic. Reasoning for the Likelihood (3/5): Possibility the lack of a policy for managing keys and physical access vulnerabilities leave a lot of people vulnerable.

2.2.4 Employee User Accounts (Active Directory)

Threats include the credential theft leading to full system access. The weak default password such as surname123 is the vulnerability in the system. This weakness leads to the impact justification 5/5, which is classified as catastrophic. Compromised admin credentials provide attacker a window to control the system and data. The Likelihood justification is 5/5, certain weak password and lack of policy make credential compromise inevitable via basic attack

2.2.5 Source Code

Threats include the theft of intellectual property and vulnerabilities, such as the outdated git server (v1.9.1) that has known vulnerabilities and shared user accounts. In this scenario the justification of the impact 4/5. This outdated software compromise availability, integrity and confidentiality of the website. This can damage the reputation of the company. Justification based on the likelihood 3/5. Since there are known vulnerability in order version of the software, it is possible to occur unauthorized access.

Tabell 2 Risk Scale: 1-4 (Low), 5-9 (Medium), 10-16 (High), 17-25 (Extreme)

Impact ➡ Likelihood ⬇	1(Low)	2	3(Medium)	4(High)	5(Catastrophic)
1 (Rare)	1	2	3	4	5
2 (Unlikely)	2	4	6	8	10
3 (Possible)	3	6	9	12	15
4 (Likely)	4	8	12	16	20
5 (Certain)	5	10	15	20	25

2.3 Risk Evaluation

2.3.1 Risk Acceptance Criteria:

Low Risk (1-4): Acceptable - Monitor periodically

Medium Risk (5-9): Acceptable with management awareness

High Risk (10-16): Unacceptable requires treatment within 3 months

Extreme Risk (17-25): Unacceptable requires immediate treatment

2.3.2 Prioritized Risk List:

Employee User Accounts (25) - Catastrophic - Immediate action required

Customer Payment Card Database (20) - Catastrophic - Immediate action required

Funds Transfer System (15) - High - Treatment within 3 months

Proprietary Source Code (12) - High - Treatment within 3 months

TLS/SSL Private Key (12) - High - Treatment within 3 months

2.4 Risk Treatment

Tabell 3 Indicating the Treatment strategies and Control

Asset	Risk Level	Treatment Strategy	Security control	Responsibility	Time Line
User Authentication Database	25 (Extreme)	Mitigate	Enforce strong password policy, Implement MFA, Regular access reviews	IT Administrator Team	Immediate
Customer Payment Card Data (PCI DSS Data)	20(Extreme)	Mitigate	Patch web server software, Deploy WAF, Network segmentation	IT Administrator Team	Immediate
Funds Transfer Execution System	15(High)	Mitigate	Privileged Access Management, Network isolation, Regular audits	Senior management	3 months
Proprietary source code	12(High)	Mitigate	Update Git server, Individual user accounts, Access logging	Senior management	3 months
TLS/SSL Private key	12(High)	Mitigate	Key management policy, Hardware Security Module	Senior management	3 months

2.5 Risk Monitoring and Reviewing

2.5.1 Monitoring

In contrast, high risks are evaluated on a quarterly basis, while extreme risks are evaluated on a monthly basis. A number of security events, a patch compliance rate, and access violation notifications are the metrics that are being followed. Devices: There are many various kinds of security solutions, two examples of which are vulnerability scanners and the Security Information and Event Management (SIEM) system.

2.5.2 Review Process

There should be participation from management as well as members of the information technology team in the risk review meetings. It is essential to keep risk assessments up to date if there are significant changes, such as the introduction of new systems or

threats. Verifying the efficiency of the controls can be accomplished through the use of penetration testing and audits.

2.6 Risk Register Maintenance

Maintain a version-controlled risk registry for e-payment services. Make a decision on who will be responsible for handling each identified risk. It is recommended to update the register after each review cycle or whenever anything significant occurs. Make it possible for those who need to know about the issue to get their hands on the necessary documents.

After implementing the selected security controls, each risk was reassessed to understand how the likelihood and impact had changed. As shown in Table 4, most of the initial Extreme and High risks were successfully reduced to a medium level. This means that the preventive actions such as stronger password policies, network segmentation, key management, and system upgrades have significantly lowered the chance of exploitation. Even though some impacts remain considerable due to the nature of financial data, the overall exposure has decreased to an acceptable level. Continuous monitoring and periodic audits will help ensure that these improvements stay effective and that any new risks are identified early.

Tabell 4 Risk Register (Updated After Controls)

Asset	Threat / Vulnerability	Risk Level	Security Controls Implemented	Likelihood After Control	Impact After Control	Residual Risk (New Level)	Remarks
User Authentication Database	Weak default passwords, no MFA	25 (Extreme)	Enforce strong password policy, implement MFA, regular access reviews	2	4	8 (Medium)	Risk reduced to acceptable level; monitor quarterly.
Customer Payment Card Data (PCI DSS Data)	SQL injection, outdated software	20 (Extreme)	Patch web server, deploy WAF, network segmentation	2	4	8 (Medium)	Acceptable after mitigation; compliance check required.
Funds Transfer Execution System	Shared SSH keys, weak VM passwords	15 (High)	Privileged Access Management, network isolation, regular audits	2	3	6 (Medium)	Residual risk acceptable with management awareness.
Proprietary source code	Key stored on USB sticks, copied to PCs	12 (High)	Hardware Security Module (HSM), key management policy	2	3	6 (Medium)	Acceptable; continue monitoring for policy compliance.
TLS/SSL Private key	Outdated Git server, shared accounts	12 (High)	Update server, individual accounts, enable access logging	2	3	6 (Medium)	Residual risk acceptable; audit bi-annually

3 Conclusion

EsacOmed's e-Payment services have been shown to be suitable for implementation of a risk management process that is designed according to ISO 27005, as proven in this paper. The areas in which EsacOmed is most vulnerable to attack were brought to light through the process of identifying critical assets, which included Customer Payment Card Data (PCI DSS Data), user authentication database, Proprietary source code, Funds Transfer Execution System and TLS/SSL Private key, and conducting an analysis of the risks that are connected with these assets.

As a provider of e-payment services, EsacOmed faces a number of key risks in the area of information security (Lundgren, 2025). This thorough risk management exercise has systematically discovered, investigated, evaluated, and managed these risks in order to

ensure that EsacOmed is able to continue providing its services in a safe and secure manner (Endro Joko Wibowo, 2022). EsacOmed's security posture will be greatly improved, and the company will be able to demonstrate that it is in compliance with the terms of the government contract if it implements the recommended procedures. The effectiveness of the risk management process will be maintained throughout time if it is continuously monitored and regularly reviewed (Endro Joko Wibowo, 2022).

4 Reference

- Endro Joko Wibowo, E. J. (2022). Impact of implementation of information security risk management and security controls on cyber security maturity (a case study at data management applications of xyz institute). *Jurnal Sistem Informasi (Journal of Information System)*, 18(2), 1-17.
- Guan, Y. &. (2024, May). Literature review on security of personal information in electronic payments. In *2024 IEEE 18th International Symposium on Applied Computational Intelligence and Informatics (SACI)*, (pp. 000533-000540). IEEE.
- Kumar, D. D. (2024). Safe and secure communication using SSL/TLS. In *2024 International Conference on Emerging Smart Computing and Informatics (ESCI)* (pp. 1-6). IEEE.
- Lundgren, M. (2025). *EsacOmed A Risk Management Exercise*.
https://ju.instructure.com/courses/15123/files/2176855?module_item_id=496397.
- Mahfud, A. Z. (2024, August). Information Security Risk Management Design Based on ISO/IEC 27005: 2022, ISO/IEC 27001: 2022, and NIST SP 800-53 Revision 5 (A Case Study at ABC Agency). In *2024 4th International Conference on Electronic and Electrical Engineering and Intelligent System (ICE3IS)*, pp. 181-186.
- Seaman, J. (2020). *PCI DSS: An integrated data security standard guide*.
- Xu, W. M. (2023). Gringotts: an encrypted version control system with less trust on servers. . *IEEE Transactions on Dependable and Secure Computing*, 21(2), 668-684.